

Change Summary

- Project: codexa
- Worktree: /path/to/codexa-worktree
- Branch: codex/general/codexa-codexa-scip-importer-20260617
- Base: main
- Primary commits: 8e4be00, 71c1b1c
- Subject: fix(static-analysis): harden SCIP report ingestion
- PR: #57
- Status: refreshed against current main, no open GitHub review comments, Codexa post-edit verdict continue

Changed Files

```
71c1b1c fix(static-analysis): validate external risk paths
src/risk-ingest.ts | 88 ++++++-----
tests/indexer.test.ts | 33 ++++++
2 files changed, 94 insertions(+), 27 deletions(-)

8e4be00 fix(static-analysis): harden SCIP report ingestion
docs/architecture/codexa-context-server.md | 12 +-
src/indexer.ts | 77 +-
src/indexer/external-facts.ts | 20 +-
src/indexer/freshness.ts | 22 +-
src/risk-ingest.ts | 159 +++-
src/scip-import.ts | 245 +++--
src/static-analysis.ts | 397 +++++--
src/symbol-report-ingest.ts | 326 +++++-
src/types.ts | 4 +
tests/indexer.test.ts | 962 ++++++
tests/static-analysis.test.ts | 1280 ++++++
11 files changed, 3292 insertions(+), 212 deletions(-)
```

Verification

- git diff --check: passed
- npm run typecheck: passed
- npm run test -- tests/indexer.test.ts tests/static-analysis.test.ts: passed, 137 tests
- npm run check: passed, including typecheck, lint, privacy, Claude integration smoke, and 364 Vitest tests
- Codexa change-plan snapshot pr57-risk-path-final-20260623: saved
- Codexa post-edit-review for pr57-risk-path-final-20260623: passed with Verdict: continue
- Codexa test-plan: reviewed; full npm run check covers recommended affected suites

Notes

Hardened SCIP conversion and external static-analysis report ingestion after adversarial review, including transactional scanner publish, report trust-boundary checks, freshness hashing, and lane ownership tests.

The final adversarial pass found one additional trust-boundary mismatch: generic, SARIF, and Semgrep risk findings accepted lexically in-repo paths even when the referenced file was missing or a symlink escape. 71c1b1c now resolves every imported external risk path through a cached realpath check before surfacing the risk, and adds regression coverage for missing files and symlink escapes.